Segurança de Redes

Network Security

Mestrado em Cibersegurança (MCS)

Mestrado em Redes de Computadores (MRC)

Departamento de Informática, Universidade do Minho

Ivo Miguel Menezes Silva

1° Semestre (26/27)

Adapted from Prof. Paulo Carvalho's (Dept. Informática – UMinho) slides, which were originally based on:
J.F Kurose and K.W. Ross, "Computer Networking: A Top-Down Approach, 8th ed., Pearson, 2020. Teaching material.

Security at Network Layer

IP/ICMP

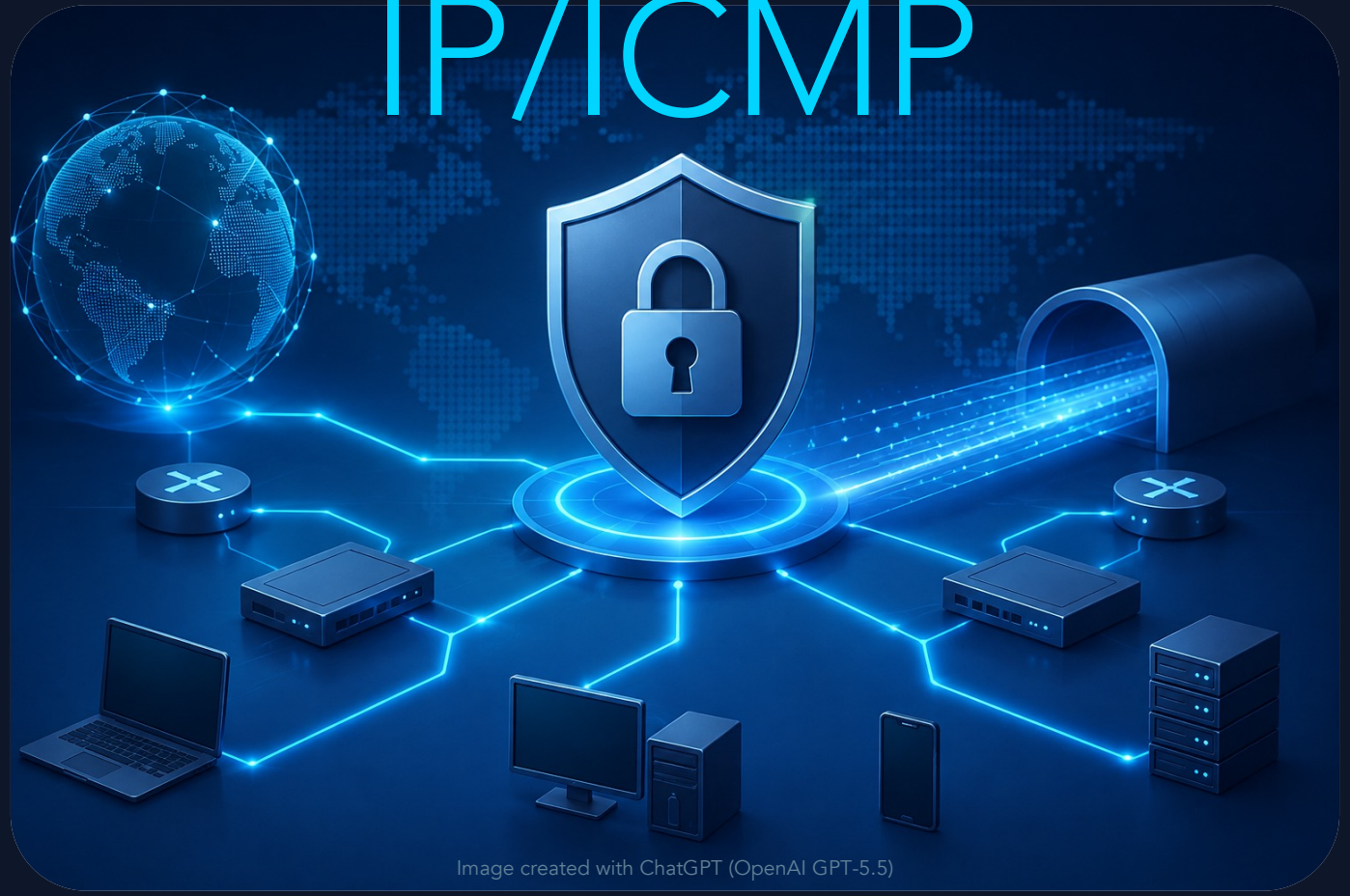


Image created with ChatGPT (OpenAI GPT-5.5)

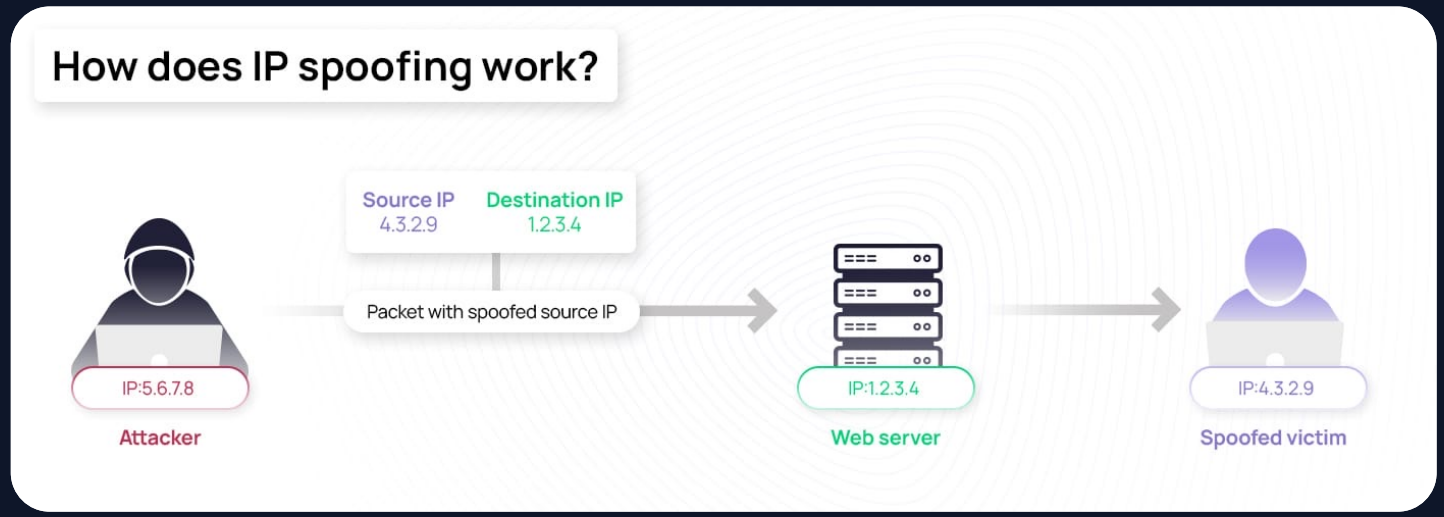
© iSilva 2026

Network Layer: IP/ICMP Attacks

1 IP Spoofing

- attackers forge IP headers to impersonate another host
- used in, e.g., DDoS amplification attacks
- the target system or intermediate network devices believe the packet is from a legitimate source
- the attacker can either flood the victim or trick the victim into interacting with a spoofed host

Mitigation: Ingress/Egress packet filtering (RFC 2827, a.k.a. BCP 38); IPsec



© iSilva 2026

Network Layer: IP/ICMP Attacks

2 ICMP flood attack (ping flood)

- overwhelm target w/ large volume of `ICMP Echo Request` packets, leading to DoS
- Mitigation: ICMP rate limiting; firewall rules to block/validate ICMP requests

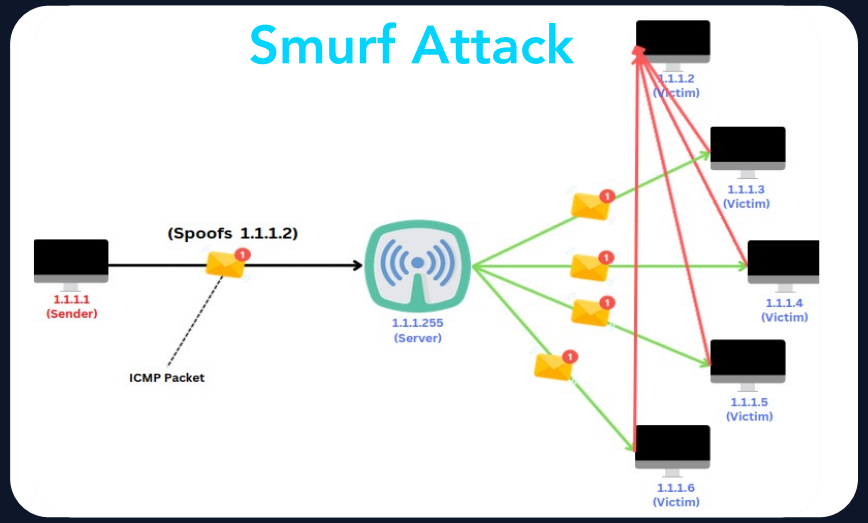
2 Smurf attack

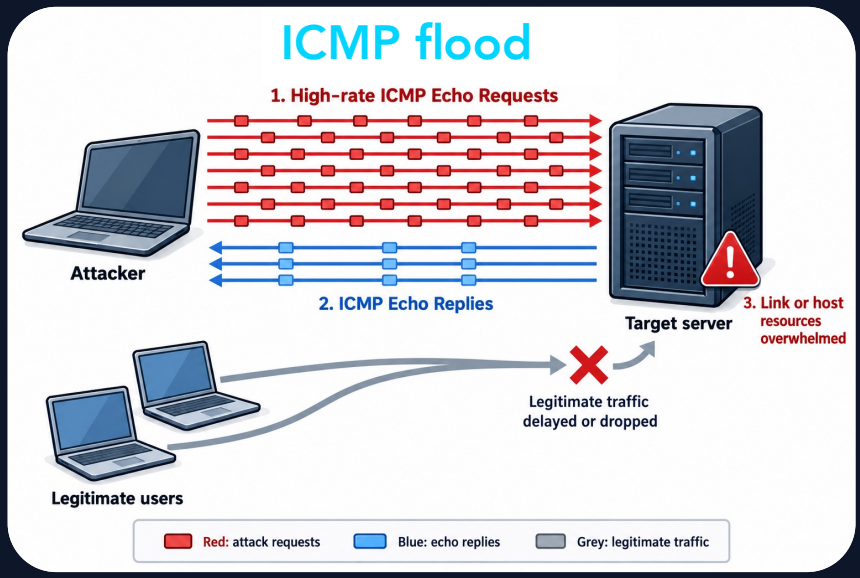
- ICMP-based amplification attack
- the attacker sends `ICMP Echo Request(s)` to a broadcast address with a spoofed source IP, resulting in a large amount of traffic directed to the victim
- Mitigation: same as above; disable ICMP broadcast

4 Ping of death

- sending oversized packets (> 64 kBytes)
  - that crash, freeze or reboot the target
- Mitigation: modern OS resilient to reassembly, firewalls, IDS/IPS can easily detect and block

Concern: legacy systems; IoT devices





© iSilva 2026

Network Layer: IP/ICMP Attacks

5️⃣ **ICMP Redirect attacks**

- attacker manipulates routing tables via ICMP Redirect messages to divert traffic, indicating the attacker's IP as the "new best route" (e.g., spoofing the default R)
- **Mitigation:** disable ICMP Redirect; use of secure routing protocols (e.g. secure OSPF)

6️⃣ **Fragmentation attacks** (e.g., Teardrop, Tiny Fragment Attack)

- exploits the fragmentation process to cause DoS or bypass filters
- attacker sends fragmented packets with overlapping fragment offsets or incomplete fragment headers, causing a crash or malfunction on reassembling
- **Mitigation:**
  - current OS are robust; patch OS against fragmentation vulnerabilities, if needed
  - packet inspection and drop abnormal fragments
  - reduce unnecessary fragmentation using Path MTU Discovery and, for TCP, appropriate MSS adjustment
  - IPv6

© iSilva 2026

Security at Network Layer

IPSec



Image created with ChatGPT (OpenAI GPT-5.5)

© iSilva 2026

Network Layer: IPsec

Goal: secure IP communications providing confidentiality, integrity, and authentication

Operation modes: transport mode (E2E) vs tunnel mode (between tunnel endpoints)

Protocols:

- **Authentication Header (AH)**: provides data integrity and authentication [RFC 4302] (less used)
- **Encapsulating Security Payload (ESP)**: provides confidentiality, integrity and data origin authentication [RFC 4303] (widely used)

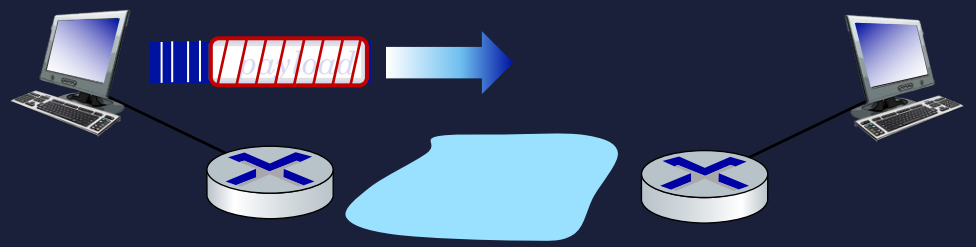
- Security Associations (SA): defines security parameters for one direction of communication
- Key exchange: uses IKE (Internet Key Exchange) protocol for establishing secure communication

© iSilva 2026

Network Layer: IPsec

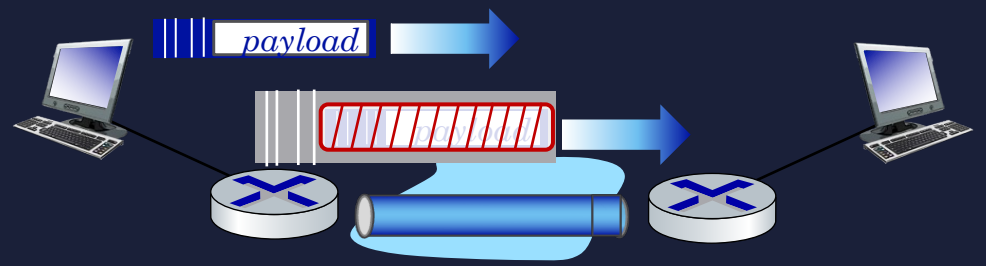
IPSec: Provides datagram-level encryption, authentication, integrity

- for both user traffic and control traffic (e.g., BGP, DNS messages)



Transport mode:

only datagram payload is encrypted, authenticated



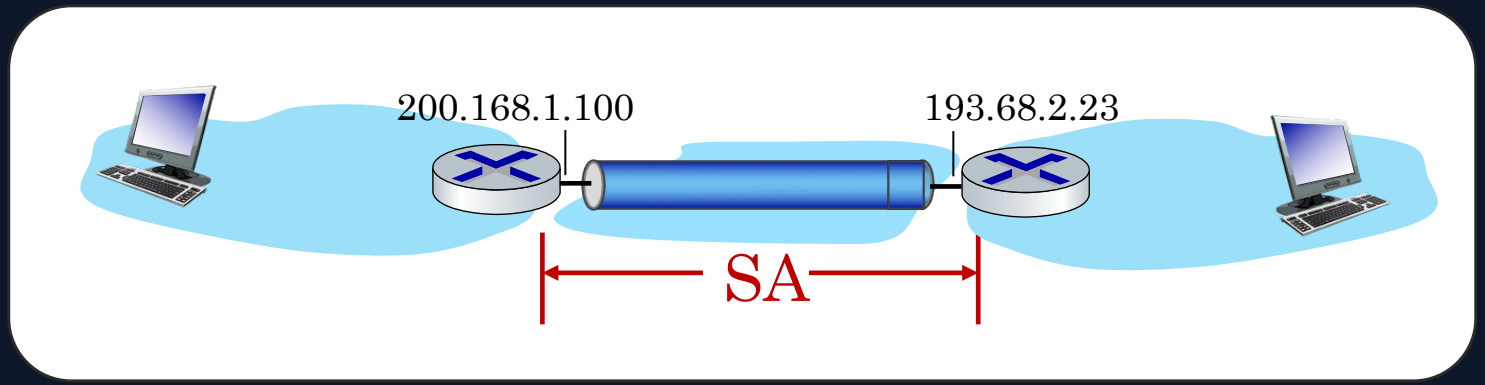
Tunnel mode:

- entire datagram is encrypted, authenticated
- encrypted datagram encapsulated in new datagram with new IP header, tunnelled to destination

© iSilva 2026

Network Layer: IPsec – Security Association

- Before sending data, a security association (SA) is established from sending to receiving entity (directional) ➡️ using the Internet Key Exchange (IKEv2) protocol [RFC 7296]
- Ending, receiving entities maintain *state information* about SA
  - IP is connectionless; IPsec is connection-oriented!



R1 stores for SA:

- 32-bit id: *Security Parameters Index (SPI)*
- origin SA interface (200.168.1.100)
- destination SA interface (193.68.2.23)
- security protocol (AH or ESP) and mode
- type of encryption used
- type of integrity check used
- encryption key; auth key
- seq# (prevent replay attacks)

© iSilva 2026

Network Layer: IPsec – SA

- *example:* manual establishment of IPsec SAs in IPsec endpoints:
  Example SA:
  SPI: 12345
  Source IP: 200.168.1.100
  Dest IP: 193.68.2.23
  Protocol: ESP
  Encryption algorithm: AES
  HMAC algorithm: SHA-2
  Encryption key: 0x7aeaca…
  HMAC key:0xc0291f…
- manual keying is impractical for VPN with 100s of endpoints
- instead use IPsec IKE (Internet Key Exchange) (recommended standard)

© iSilva 2026

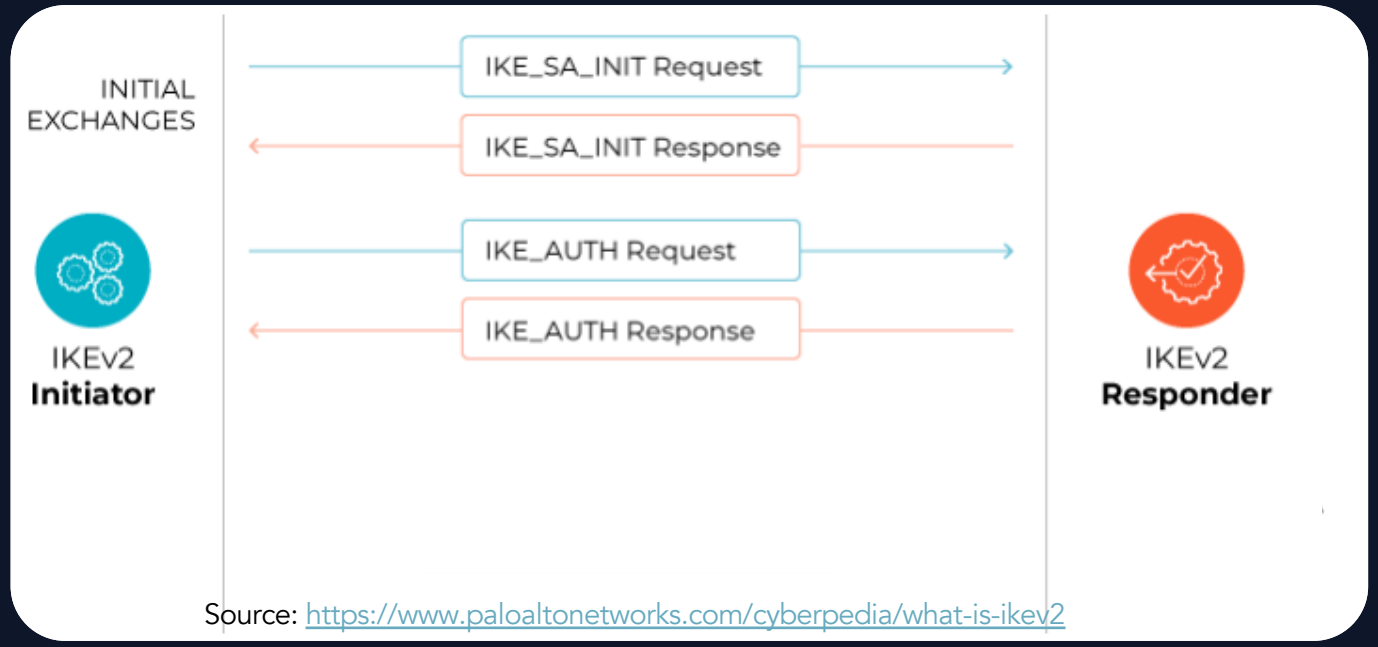
Network Layer: IPsec – IKE

- authentication (prove who you are) with either
  - pre-shared secret (PSK) or
  - public key infrastructure (PKI)
- PSK: both sides start with secret
  - during the IKE exchange, each peer uses this shared secret to authenticate the other side
  - after IKE is used to authenticate each other, IPsec SAs are generated (one in each direction), including encryption, authentication keys
- PKI: both sides start with public/private key pair issued by a trusted Certificate Authority (CA)
  - run IKE to authenticate each other without needing a pre-shared secret, allowing to obtain IPsec SAs (one in each direction)
  - similar to the TLS handshake

© iSilva 2026

Network Layer: IPsec – IKEv2 handshaking (1/2)

- IKE_SA_INIT
  - negotiates security parameters and performs Diffie-Hellman key exchange
- IKE_AUTH
  - authenticates the peers, establishes IPsec SAs, and defines the traffic to be protected



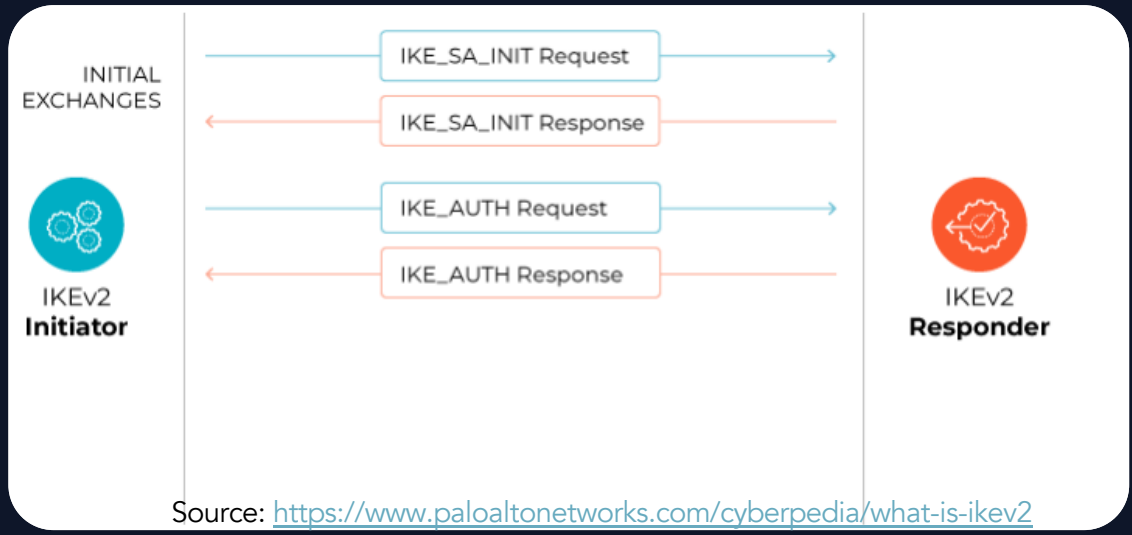
Source: https://www.paloaltonetworks.com/cyberpedia/what-is-ikev2

© iSilva 2026

Network Layer: IPsec – IKEv2 handshaking (2/2)

- **Step 1 (IKE_SA_INIT Request):** The initiator proposes cryptographic algorithms and sends its Diffie-Hellman public value and a nonce, a fresh random value.
- **Step 2 (IKE_SA_INIT Response):** The responder selects the algorithms and returns its Diffie-Hellman public value and nonce. Both peers can now derive keys to protect subsequent IKE messages, but their identities have not yet been authenticated.
- **Step 3 (IKE_AUTH Request):** Inside a protected message, the initiator provides its identity and authentication proof, and proposes parameters for the first IPsec Child SA, including which traffic to protect.
- **Step 4 (IKE_AUTH Response):** The responder provides its identity and authentication proof and confirms the negotiated Child SA parameters. On success, the authenticated IKE SA and the first pair of IPsec SAs are established.

A CREATE_CHILD_SA exchange is an optional exchange that can establish additional SAs or replace existing SAs with fresh keys, a process called rekeying. It is not needed to create the first pair in this basic handshake.

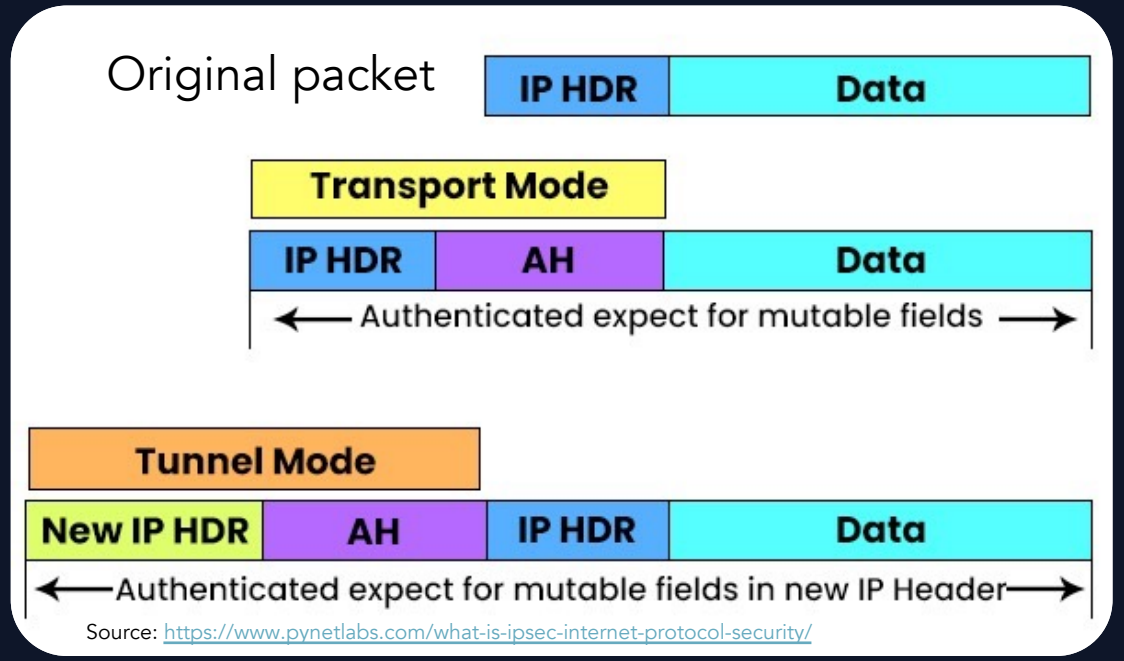


Source: https://www.paloaltonetworks.com/cyberpedia/what-is-ikev2

© iSilva 2026

Network Layer: IPsec protocols (Authentication Header)

- **Authentication Header (AH):** provides integrity and data origin authentication. It allows the receiver to detect unauthorised changes and verify that the packet came from a peer possessing the correct secret key.
- AH does not encrypt anything. The packet contents remain readable, even in tunnel mode. It can also protect against replay attacks when the receiver enables sequence number checking.
- **Modes**
  - **Transport mode:** AH header is inserted between the original IP header and the transport header, such as TCP or UDP.
  - **Tunnel mode:** a new outer IP header is added, followed by AH and then the entire original IP packet. The outer addresses identify the tunnel endpoints.

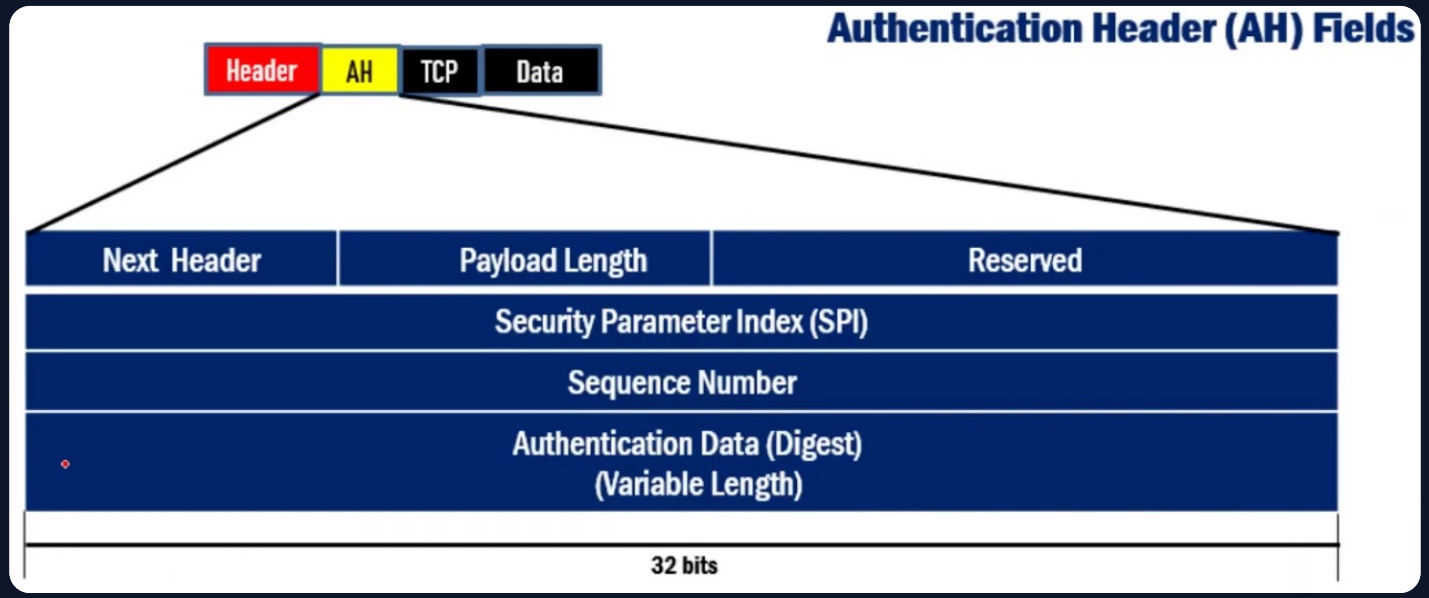


Source: https://www.pynetlabs.com/what-is-ipsec-internet-protocol-security/

© iSilva 2026

Note: * In Tunnel Mode, a new IP header is added, and the entire original IP packet is encapsulated. The AH header is placed between the new and the original IP header.

Network Layer: IPsec protocols (Authentication Header)



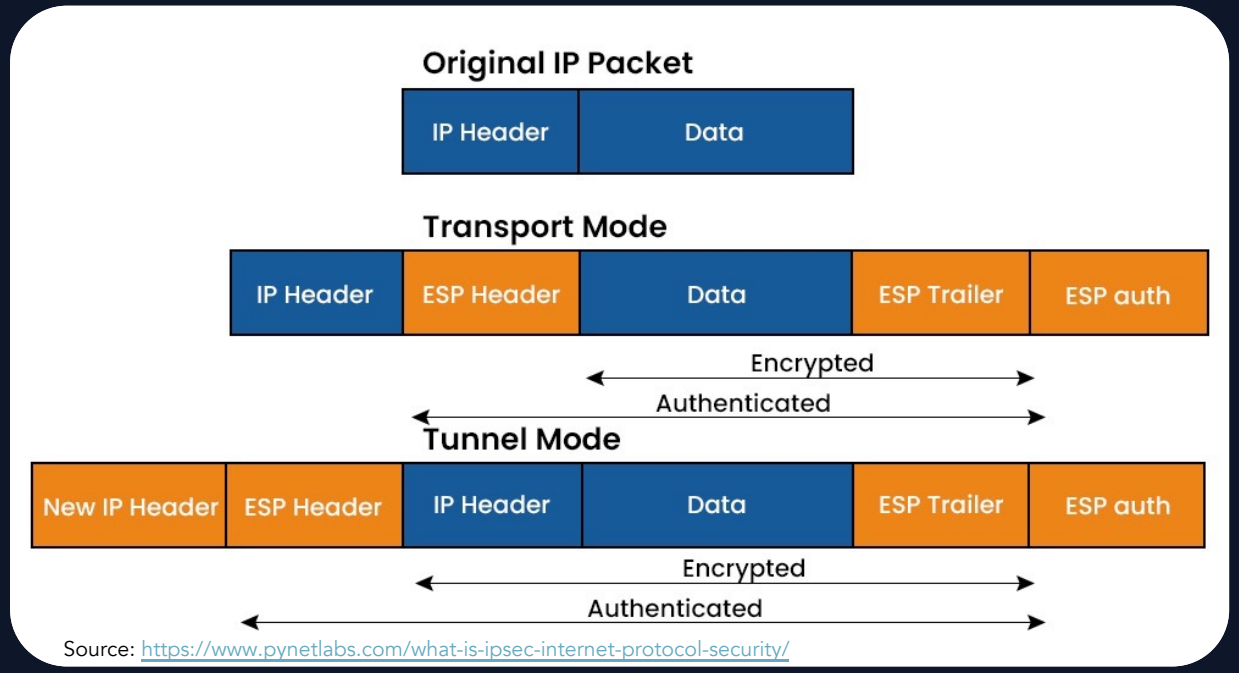
- Next Header – payload type (TCP, UDP, IP, OSPF, etc.) of the original IP datagram
- Payload Length – AH length in multiple of 4 bytes
- Security Parameter Index (SPI) – identifies the security association between sender and receiver
- Sequence Number – increasing counter used for replay protection to avoid replay attacks
- Authentication Data – digest from hashing the full datagram (immutable fields); its length is determined by the MAC algorithm negotiated for the SA (HMAC-SHA256, HMAC-SHA384, etc.)

Note: * In Tunnel Mode, a new IP header is added, and the entire original IP packet is encapsulated. The AH header is placed between the new and the original IP header.

© iSilva 2026

Network Layer: IPsec protocols
Encapsulating security payload (ESP)

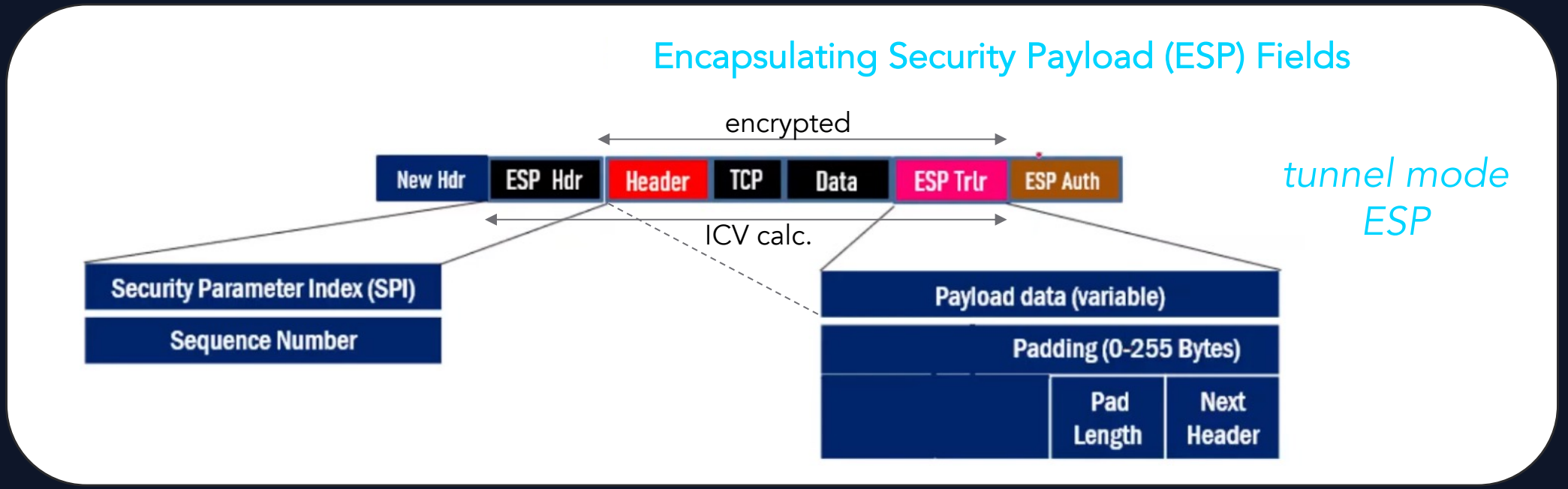
- **ESP** can provide confidentiality, integrity, data origin authentication, and replay protection.
- **Unlike AH, ESP supports encryption**: AH authenticates selected IP header fields; ESP does not protect the outer IP header.
- **Modes**
  - **Transport mode:** protects the original IP payload, including the TCP/UDP header. The original IP header remains visible.
  - **Tunnel mode:** protects the entire original IP packet. A new outer IP header identifies the tunnel endpoints.



Source: https://www.pynetlabs.com/what-is-ipsec-internet-protocol-security/

© iSilva 2026

Network Layer: IPsec protocols
Encapsulating security payload (ESP) Fields



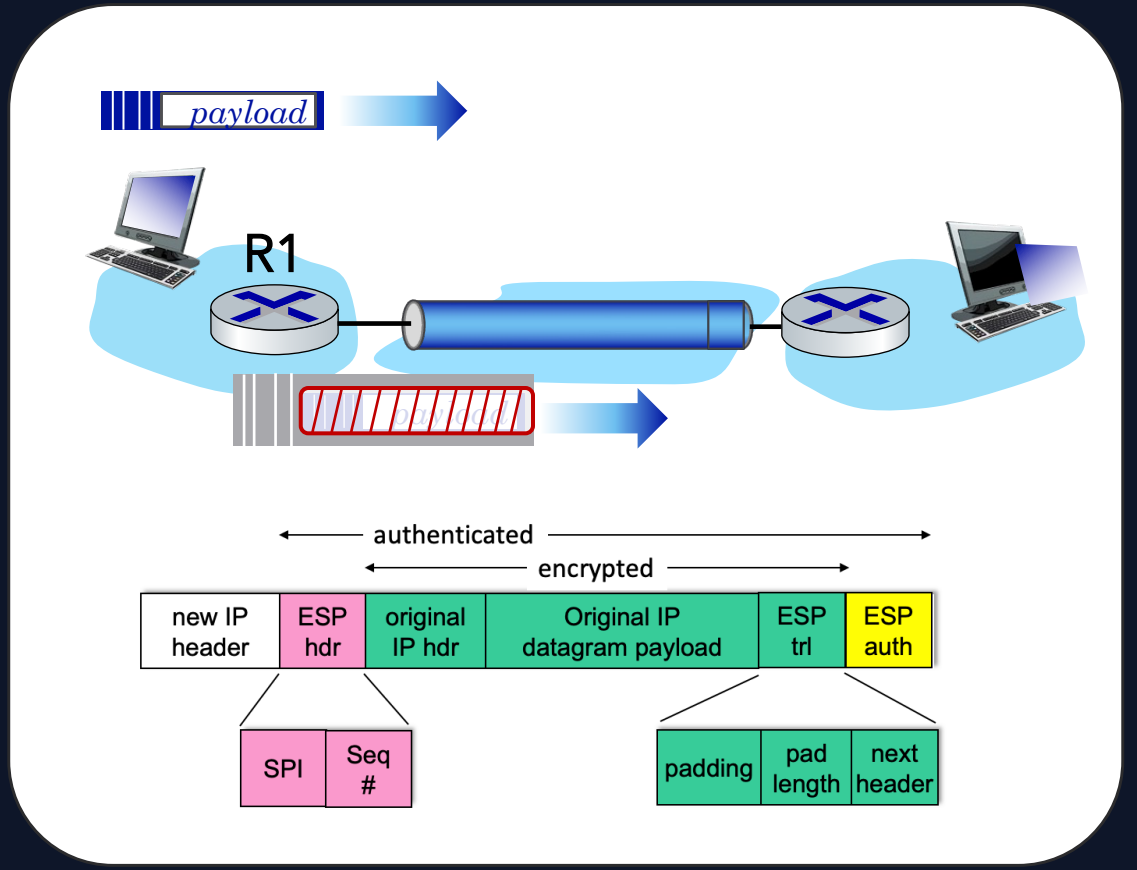
- Payload data – original datagram
- Padding (and Pad Length) – added to meet the required length for block ciphers (e.g., 16-byte blocks)
- Next Header – payload type (TCP, UDP, IP, OSPF, etc.) of the original IP datagram
- Security Parameters Index (SPI) – identifies the security association between sender and receiver
- Sequence Number – nonce to avoid replay attacks; incremented per datagram sent
- ESP Auth or Integrity Check Value (ICV) – digest from hashing original datagram, ESP header and trailer
- New Hdr - new header for tunnel mode with protocol field value 50 (ESP)

© iSilva 2026

Network layer: ESP tunnel mode

Actions at R1

- appends ESP trailer to original datagram (which includes original header fields!)
- encrypts result using algorithm and key specified by SA
- appends ESP header to front of this encrypted quantity
- creates authentication MAC (ESP auth) using algorithm and key specified in SA
- appends MAC forming *new payload*
- creates new IP header, new IP header fields, addresses to tunnel endpoint



© iSilva 2026

IPsec: Sequence Numbers and Replay Protection

- **Problem:** an attacker can resend valid, authenticated packets to disrupt a service (replay attack).
- **Sender:** starts the SA's counter at 0, increments it for each packet, and includes the value in the sequence number field.
- **Receiver:** uses an anti-replay sliding window to detect duplicates without tracking every previously received packet.
- The window allows some reordering, but rejects duplicates and packets that are too old.
- Severe reordering: legitimate packets may be discarded; increasing the window size can help.

© iSilva 2026

Network Layer: IPsec deployment

- VPNs – IPsec is a foundational technology in many VPN solutions Specifically, IPsec in tunnel mode is used in
  - site-to-site VPNs: to connect corporate branches over the Internet securely
  - remote access VPNs: allow employees to connect to their corporate network from anywhere using secure encrypted tunnels
- Enterprise Networks – large enterprises use IPsec to secure internal traffic, especially when dealing with sensitive or critical data, e.g.,
  - between data centers
  - for ensuring that internal comm. across parts of the network are protected
- Telecom and ISPs
  - some use IPsec in their backbone to secure traffic between regional points of presence (POPs) and between their infrastructure elements

© iSilva 2026

Network Layer: IPsec summary

- IKEv2 messages negotiate algorithms and SPIs, derive secret keys, and establish SAs.
- use AH or ESP protocols
  - AH provides integrity, source authentication
  - ESP can provide encryption, integrity, and data origin authentication (widely used)
- IPsec peers can be two end-systems, two routers/firewalls, or a router/firewall and an end system
- Still security vulnerabilities?
  - yes, mainly resulting from: IPSec misconfiguration or implementation flaws, use of weak cypher suites, or unpatched systems; it doesn't obfuscate traffic

© iSilva 2026

Network Layer: IPsec summary



Trudy sits somewhere between **R1**, **R2**; she doesn't know the keys

- will Trudy be able to see original contents of datagram?
- how about source, destination IP addresses, transport protocol, application ports?
- flip bits without detection?
- masquerade as R1 using R1's IP address?
- replay a datagram?

© iSilva 2026

Quizz